Guía del estudiante

Ciberseguridad Aplicada — cómo se trabaja y se entrega

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

1 Cómo funciona el curso

El curso se organiza en 10 semanas agrupadas en 5 fases. Cada semana tiene una práctica de laboratorio que se entrega al terminar la sesión. No hay proyecto integrador: lo que se evalúa es el trabajo de cada semana y la capacidad de sostener el criterio en la evaluación final.

2 Grupos y roles

El curso trabaja con 4 grupos. Fija durante el semestre; cada grupo entrega sus propias prácticas.

- Rojo: Ejecuta la técnica ofensiva sobre el objetivo autorizado: prepara el entorno, lanza el ataque, registra comandos y payloads, y guarda cada salida con su hash. Aporta: Evidencia cruda en semana_NN/evidencia y el apartado de reproducción del informe.
- Azul: Parte de su propia captura cruda y aplica el control equivalente: configuración, parche o regla de red. Repite el ataque para demostrar que falla y documenta el antes y el después. Aporta: La mitigación aplicada, el comando de verificación y la comparación de resultados.
- Púrpura: Instrumenta la detección del mismo evento: activa el registro, define la alerta y mide lo que se habría visto, incluidos los falsos positivos y negativos. Aporta: La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
- Legal y reporte: Verifica que el alcance y la autorización cubran lo ejecutado, anonimiza la evidencia, revisa la cadena de custodia e integra el informe técnico y el resumen ejecutivo. Aporta: La versión final del informe y la declaración explícita de lo que no se pudo verificar.

Los roles rotan una posición al inicio de cada fase (de la 1 a la 4), de modo que cada grupo pasa por las cuatro perspectivas. En la fase 5 no hay roles de grupo; la evaluación final es individual.

Asignación de roles por rotación (idéntica en cada grupo)

Rotación	Integrante 1	Integrante 2	Integrante 3	Integrante 4
Fase 1	Rojo	Azul	Púrpura	Legal y reporte
Fase 2	Azul	Púrpura	Legal y reporte	Rojo
Fase 3	Púrpura	Legal y reporte	Rojo	Azul
Fase 4	Legal y reporte	Rojo	Azul	Púrpura

Cada grupo crea un repositorio GitHub propio (privado, con el docente como colaborador) y lo mantiene actualizado. El docente revisa ese repositorio al finalizar cada semana de práctica.

3 Repositorio GitHub y entregas

La entrega se hace en GitHub. Un repositorio privado por grupo, con el docente como colaborador de lectura.

El docente revisa el repositorio al finalizar cada semana de práctica.

Corte de cada semana: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

Estructura del repositorio

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_NN/informe.md o informe.pdf con el entregable de esa práctica.
- semana_NN/scripts/ con el código, con type hints y docstrings.
- semana_NN/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_NN/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas de entrega

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

> **Antes de empezar:** el trabajo se hace desde el equipo y la conexión de cada grupo. El único objetivo permitido es el laboratorio local (o el entorno propio declarado) y los sistemas con autorización escrita; nunca la infraestructura de la universidad ni de terceros.

4 Puesta en marcha del laboratorio

El docker-compose de esta carpeta es opcional. Cada grupo puede usar su propio entorno en su PC siempre que respete el alcance autorizado.

Requiere ~2 GB de RAM libre y ~5 GB de disco; DVWA y Juice Shop juntos consumen menos de 700 MB.

Si se usa el laboratorio de la carpeta del curso, se levanta con docker compose -f laboratorio/docker-compose.yml up -d. Los servicios quedan accesibles solo en localhost y en la red doméstica de cada grupo.

Servicio	Imagen	URL local
objetivo-web	`vulnerables/web-dvwa:latest`	`localhost:8081`
objetivo-juice	`bkimminich/juice-shop:latest`	`localhost:3000`
objetivo-linux	`ubuntu:24.04`	`localhost:2222`

Recuerda

Para reiniciar el laboratorio a su estado inicial: `docker compose down -v` y volver a levantarlo. Ningún cambio debe sobrevivir entre prácticas sin documentarse.

- {'Cada grupo trabaja desde su propio equipo y red': 'no hay red compartida del curso.'}
- El laboratorio corre en localhost y nunca se expone a Internet.
- Solo se atacan contenedores del laboratorio o sistemas con autorización escrita y firmada.
- {'Las muestras de malware no se ejecutan': 'el análisis es estático y sobre copias inertes.'}
- La evidencia se anonimiza antes de entregarse; los datos personales no salen del laboratorio.
- Se prohíbe el uso de estas técnicas contra la infraestructura de la universidad o de terceros.

5 Contrato de datos de los scripts

Concepto clave

Todo script entregado imprime **un solo objeto JSON** por la salida estándar y devuelve un diccionario con estas claves. `status` vale `ok` o `error`; si es `error`, `errores` explica el motivo y el programa sale con código distinto de cero.

```
{
  "status": "ok",
  "objetivo": "172.28.0.10",
  "duracion_s": 12.4,
  "hallazgos": [
    {"puerto": 80, "servicio": "http", "version": "nginx"}
  ],
  "errores": []
}
```

- Type hints en todas las funciones públicas y docstrings estilo Google.
- Errores manejados explícitamente: nunca se devuelve una lista vacía para ocultar un fallo.
- Sin rutas absolutas ni credenciales en el código.
- Salida determinista: mismo objetivo y mismas opciones producen la misma estructura.

6 Evaluación

Concepto	Peso (%)
Prácticas de laboratorio (semanas 1-9)	35,0
Controles de fase (semanas 3, 5 y 7)	10,0
Evaluación teórica del trabajo de grupo (semanas 2-9)	5,0
Informes técnicos (semanas 5, 7 y 9)	15,0
Evaluación final práctica (semana 10)	25,0
Ética, autorizaciones y uso responsable	10,0

Cada práctica se corrige con la rúbrica de diez puntos incluida en su propio documento. Entregar fuera de plazo descuenta según el reglamento de la asignatura; entregar sin evidencia anonimizada se devuelve sin corregir.

7 Ética y legalidad

- Cada grupo mantiene su propio repositorio GitHub y lo entrega actualizado antes del corte semanal; el docente revisa ese repositorio.
- {’El trabajo se hace desde el equipo y la conexión de cada grupo’: ’solo objetivos propios, el laboratorio provisto o sistemas con autorización escrita; nunca infraestructura de la universidad ni de terceros.’}

- Solo se atacan objetivos propios o con autorización escrita y firmada.
- El laboratorio es local y nunca se expone a Internet.
- Las muestras de malware no se ejecutan y se manejan como copias inertes.
- La evidencia se anonimiza antes de entregarse.
- El uso indebido de las técnicas del curso tiene consecuencias académicas y legales.
- El código entregado usa type hints, docstrings estilo Google y manejo explícito de errores.

8 Calendario resumido

Sem.	Tema	Entregable
1	Panorama de la ciberseguridad y superficie de ataque	Tabla de activos y servicios, modelo STRIDE y conclusión priorizada de tres vectores.
2	Criptografía aplicada y gestión de secretos	Registro de comandos, salidas y una tabla que asigne cada primitiva a la propiedad que garantiza.
3	Marco legal, ético y normativo	Autorización firmada, análisis del caso y código de ética firmado por cada estudiante.
4	Reconocimiento, OSINT y escaneo de puertos	Script integrado (huella digital + escáner), salida JSON, huella digital razonada, tabla comparativa con nmap y análisis de falsos positivos.
5	Vulnerabilidades web según OWASP Top 10	Informe técnico con payloads, evidencia anonimizada, causa raíz y mitigación por hallazgo.
6	Hardening, firewall y detección	Auditor propio, hardening antes/después, reglas de firewall, comparativa de alcance y alertas de Suricata clasificadas.
7	Desarrollo seguro y cadena de suministro	Parches, evidencia antes y después con el mismo payload, y salida de los tres controles.
8	Forense digital: adquisición, artefactos y línea de tiempo	Imagen forense con hashes, formulario de custodia, línea de tiempo, relato del incidente y tabla de IoCs.
9	Respuesta a incidentes y triage estático de malware	Playbook de una página, informe de triage y regla YARA probada, más post mortem.
10	Evaluación final práctica de alcance cerrado	Informe técnico, resumen ejecutivo, evidencia preservada y defensa oral.